IT GOVERNANCE
Suggested Answers
Mar-Apr 2022

Answer to the Question # 1 (a):
Online VAT registration will reduce time, cost of compliance and hassle to obtain VAT registration for companies/business firms. This will also increases the taxpayers' compliance rate, which will also increase VAT collection. Online Tax filing will introduce online tax payment system either collectively or successively for a whole financial year. Allowing citizens to file tax returns at their convenience from the comfort of their home will save citizens time, money and hassle, resulting in high rate of tax filing and collection.

Answer to the Question # 1 (b):
The obligations have been fulfilled. The relevant act stipulates that, where any law requires that any law, rule, regulation, order, bye-law, notification or any other matter shall be published in the Official Gazette, then, such requirement shall be deemed to have been satisfied if such law, rule, regulation, order, bye-law, notification or any other matter is published in the Official Gazette or Electronic Gazette.

Answer to the Question # 1 (c):
The earlier of the two dates will be deemed as the date of publication. The relevant act is, provided that where any law, rule, regulation, order, bye-law, notification or any other matter is published in the Official Gazette or the Electronic Gazette, the date of publication shall be deemed to be the date of the Gazette which was first published in any form.

Answer to the Question # 2:
Fintech in Bangladesh has totally changed the financial landscape. There have been several growing fintech companies in Bangladesh over the years. Since the pandemic has inspired people into cashless transactions, fintech companies in Bangladesh have welcomed this opportunity to make a meaningful and noteworthy impact in Bangladesh.

Creating Opportunities for Financial Access

Digital banking can radically change the lives of the people working in the informal sector. MFS and Agent banking are considered key drivers in the financial inclusion strategy by providing low-income groups and disadvantaged people access to financial services at affordable costs. MFS transactions rose by around 30% since last year and till March agent banking has seen 108.38% year-on-year growth in deposits.

Financial Institutions can Know Their Customers Better

It's no surprise that Big Data, Machine Learning, and Artificial Intelligence are driving many business decisions in the modern age. Financial services in many countries use big data to screen potential clients. The system can do extensive background checks in a flash. All these can help to reduce and prevent money loss for loaners who can assess the viability of a loan or investment. The whole system is intuitive, smooth, and easy to use and most of all, it gives accurate results and predictions.

For financial institutions in Bangladesh, this technology is crucial. The percentage of bad loans and poor investments is staggering with 11.4% of recipients defaulting. In the first quarter of 2021, defaulted loans accounted for 8.07% of total outstanding loans. Fintech which assists in digitally retrieving customer data and calculating expected loss can help reduce that percentage by a significant amount. They can not only reduce time but also improve customer satisfaction.

Increased Efficiency Leading to Enormous Cost Reductions

Technology penetration is approximately less than 40% in Bangladesh. There are several financial services that can be automated. Fintech can bring personalized ledger systems and real-time investment plans to the table. Online transactions can take place much faster with more security. Even big data can help banks catch on to market trends in the blink of an eye; data is the new currency.

Fintech offering financial management services is delivering a transformational user experience, by enabling the users to track their bank accounts, credit card details, investment details, loan balances, and transactions. They can also

enhance services by implementing chatbots which are essentially software robots that can converse with customers, enhancing their banking experience.

Remittances are also an important part of the economy. Still, the process is suboptimal. There are many hidden conversion and handling fees that financial institutes have to bear. Apart from remittances, banks also incur costs when sending or receiving money. Fintech can help reduce a lot of these costs.

Updating customer databases and managing customer profiles become much faster with the implementation of technology. The reduced administrative lag can go a long way in helping reduce costs in the long run.

Substantial Security Benefits

Financial institutes in Bangladesh are far behind in cyber security and risk management. Recently, 147 public and private organizations – including banks and non-bank financial institutions (NBFIs), came under cyber attacks. Bangladesh Bank itself has often faced cyber-attacks which led them to lose millions of dollars.

Integrating artificial intelligence and machine learning for fraud detection, blockchain systems, and regulatory technologies (RegTech) with financial services, will help build a secure system. E-KYC can also help in preventing money laundering activities by enhancing customer identification and authentication processes.

Fintech-enabled payment processing can help bring more cash transactions under the formal sector, thereby mitigating malpractices, improving transparency, and providing better fund protection for customers. Digital payments can also reduce the amount of money to be printed, thus reducing the risks of counterfeit money. It can also help financial institutions maintain consistency in their operations and reduce the risks of error.

Reach Wider Markets

Fintech in Bangladesh is particularly important because to date the majority of the population in Bangladesh lives in rural areas. To attain SDG goals it is important that the rural residents aren't deprived of any financial services. With the help of the internet and the booming number of fintech companies in Bangladesh, that vision isn't far away.

With the internet, we are all connected. There's no reason why financial entities shouldn't hop on that train. Financial institutes can introduce their services to a wider market.

Bangladesh's financial markets where stocks, bonds, etc. are sold could see a significant transformation by leveraging Fintech. Starting from financial advisory, domestic and international online trading platforms to using technology to improve regulation in stock exchanges, the potential for Fintech in Bangladesh is massive. Wealth management, for example, has been one of the financial services that have been disrupted in a big way by FinTech. With the implementation of big data, artificial intelligence, blockchain, and other supportive technologies like RegTech, the financial markets will work more efficiently and securely.

Fintech companies in Bangladesh should be encouraged to help create accessible and affordable consumer credit products such as peer-to-peer (P2P) lending platforms, crowdfunding platforms, and alternative credit scoring apps. Insurance companies in Bangladesh should widely accept insurance in their operations for wider availability of insurance products, increased accountability, and transparency.

Answer to the Question # 3:

Disadvantages of Decision Support Systems (DSS)

Decision Support Systems can create advantages for organizations and can have positive benefits, however building and using DSS can create negative outcomes in some situations.

Monetary cost: The decision support system requires investing in information system to collect data from many sources and analyze them to support the decision making. Some analysis for Decision Support System needs the advance of data analysis, statistics, econometrics and information system, so it is the high cost to hire the specialists to set up the system.

Overemphasize decision making: Clearly the focus of those of us interested in computerized decision support is on decisions and decision making. Implementing Decision Support System may reinforce the rational perspective and overemphasize decision processes and decision making. It is important to educate managers about the broader context of decision making and the social, political and emotional factors that impact organizational success. It is especially important to continue examining when and under what circumstances Decision Support System should be built and used. We must continue asking if the decision situation is appropriate for using any type of Decision Support System and if a specific Decision Support System is or remains appropriate to use for making or informing a specific decision.

Assumption of relevance: According to Wino grad and Flores (1986), "Once a computer system has been installed it is difficult to avoid the assumption that the things it can deal with are the most relevant things for the manager's concern." The danger is that once DSS become common in organizations, that managers will use them inappropriately. There is limited evidence that this occurs. Again training is the only way to avoid this potential problem.

Transfer of power: Building Decision Support Systems, especially knowledge-driven Decision Support System, may be perceived as transferring decision authority to a software program. This is more a concern with decision automation systems than with DSS. We advocate building computerized decision support systems because we want to improve decision making while keeping a human decision maker in the "decision loop". In general, we value the "need for human discretion and innovation" in the decision making process.

Unanticipated effects: Implementing decision support technologies may have unanticipated consequences. It is conceivable and it has been demonstrated that some DSS reduce the skill needed to perform a decision task. Some Decision Support System overload decision makers with information and actually reduce decision making effectiveness.

Obscuring responsibility: The computer does not make a "bad" decision, people do. Unfortunately some people may deflect personal responsibility to a DSS. Managers need to be continually reminded that the computerized decision support system is an intermediary between the people who built the system and the people who use the system. The entire responsibility associated with making a decision using a DSS resides with people who built and use the system

False belief in objectivity: Managers who use Decision Support Systems may or may not be more objective in their decision making. Computer software can encourage more rational action, but managers can also use decision support technologies to rationalize their actions. It is an overstatement to suggest that people using a DSS are more objective and rational than managers who are not using computerized decision support.

Status reduction: Some managers argue using a Decision Support System will diminish their status and force them to do clerical work. This perceptual problem can be a disadvantage of implementing a DSS. Managers and IS staff who advocate building and using computerized decision support need to deal with any status issues that may arise. This perception may or should be less common now that computer usage is common and accepted in organizations.

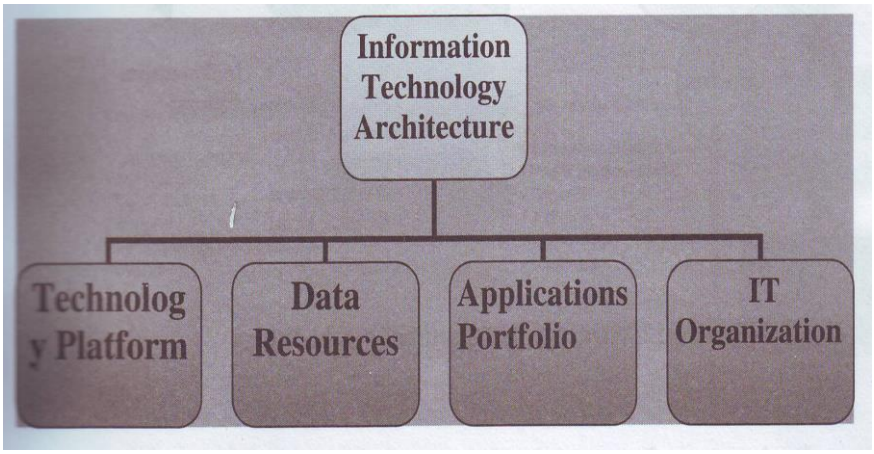
Information overload: Too much information is a major problem for people and many DSS increase the information load. Although this can be a problem, Decision Support System can help managers organize and use information. Decision Support System can actually reduce and manage the information load of a user. Decision Support System developers need to try to measure the information load created by the system and Decision Support System users need to monitor their perceptions of how much information they are receiving. The increasing ubiquity of handheld, wireless computing devices may exacerbate this problem and disadvantage.

Answer to the Question # 4 (a):

Clearly, organizations need to be developing strategy differently. How to do this is not always apparent, but several organizations try ways to more dynamically link IT strategy with the overall business strategy. Before developing an IT strategy for an organization, it is mandatory to have effective information technology architecture of that organization.

Information Technology Architecture

The IT includes the following major components:



Information technology architecture

Technology Platform: The Internet, intranets, extranets, and other networks, computer systems, system software, and integrated enterprise application software provide a computing and communications infrastructure, or platform that supports the strategic use of information technology of an organization.

Data Resources: Many types of operational and specialized databases, including data warehouses and Internet/intranet databases store and provide data and information for business processes and decision support.

Applications Portfolio: Business applications of information technology are designed as an integrated portfolio of information systems that support strategic business initiatives, as well as cross-functional business processes.

IT Organization: The organizational structure of the Information System (IS) function within a company and the distribution of IS specialists is designed to meet the changing strategies of a business. The form of the IT organization depends on the managerial philosophy, e-business vision, and business/IT strategies formulated during the strategic planning process.

Answer to the Question # 4 (b):
Now, we can consider four aspects of strategy:

(i) Scope of operations,
(ii) Resource allocation,
(iii) Competitive advantage, and
(iv) Synergy.

These aspects of strategy are described below.

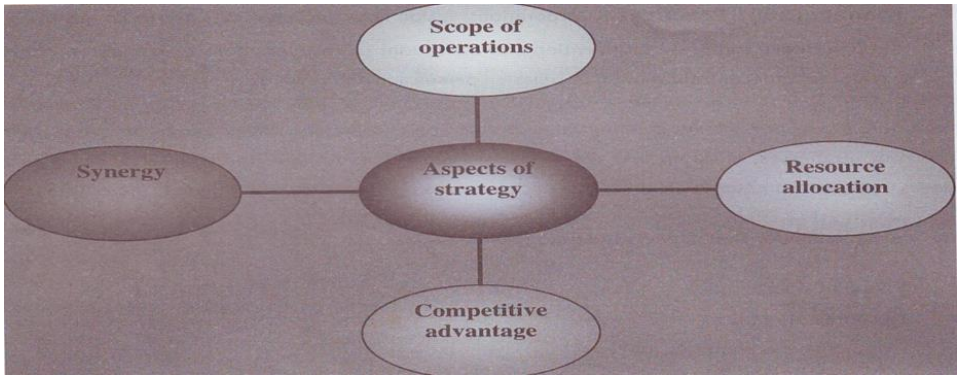
i) Scope of Operations

The first component encompasses the geographic locations—countries and regions—of possible operations as well as possible markets or niches in various regions. Since companies have limited resources and different regions offer different advantages, managers must select the markets that offer the company the optimal opportunities.

ii) Resource Allocation

The second component of the global strategy focuses on use of company resources so that a company can compete successfully in the chosen markets. This component of strategy planning also determines the relative importance of various company functions and bases the allocation of resources on the relative importance of each function. For instance, a company may decide

to allocate its resources based on product lines or geographical locations.



Aspects of strategy

iii) Competitive Advantage

Next, management must decide where the company can achieve competitive advantage over other companies in the industry. Management can identify their competitive advantage by determining what the company does better (or can do better) than its competitors. Companies may realize this advantage through a host of techniques such as using superior technology, implementing more efficient organizational practices and distribution systems, and cultivating well-known brands. This component of the strategy involves not only identifying existing or potential areas of competitive advantage but also developing a plan for sustaining areas of competitive advantage.

iv) Synergy

Finally, global strategy should involve establishing a plan for the company that enables its various functions and operations to benefit one another. For example, a company can use one line of products to encourage sales of another line of products and thereby enabling different parts of a business to benefit from each other. Many companies are now outsourcing many of their operations internationally. For example, if all to get information on your credit card, you may well be talking to someone in India or Mexico. Equally, manufacturers often outsource production to low labor cost countries. Concerns over ethical issues, such as slave and child labor, have led to companies outsourcing under controlled conditions—offshore production may be subject to surprise visits and searches and outsourced factories are required to conform to specific criteria.

Answer to the Question # 5 (a):

i) Users at the client layer can cause harm by introducing errors or by accessing systems without authorization.

ii) It is possible to access data flowing over networks, steal valuable data during transmission, or alter data without authorization. Radiation may disrupt a network at various points as well. Thus, it may be get exposed to tapping, sniffing, message alteration, theft and fraud.

iii) Intruders can launch denial-of-service attacks or malicious software to disrupt the operation of websites. As such, there are risks of hacking, malware, and vandalism.

iv) Those capable of penetrating corporate systems can steal, destroy, or alter corporate data stored in databases or files. Moreover, floods, fires, power failures, and other electrical problems can cause disruptions at any point in the network.

Moreover, floods, fires, power failures, and other electrical problems can cause disruptions at any point in the network.

Answer to the Question # 5 (b):

A computer virus is a rogue software program that attaches itself to other software programs or data files to be executed, usually without user knowledge or permission. Most computer viruses deliver a payload. The payload may be relatively benign, such as instructions to display a message or image, or it may be highly destructive—destroying programs or data, clogging computer memory, reformatting a computer's hard drive, or causing programs to run improperly.

Viruses typically spread from computer to computer when humans take an action, such as sending an e-mail attachment or copying an infected file. Worms are independent computer programs that copy themselves from one computer to other computers over a network. Unlike viruses, worms can operate on their own without attaching to other computer program files and rely less on human behavior to spread from computer to computer. This explains why computer worms spread much more rapidly than computer viruses. Worms destroy data and programs as well as disrupt or even halt the operation of computer networks.

Worms and viruses are often spread over the Internet from files of downloaded software; from files attached to e-mail transmissions; or from compromised e-mail messages, online ads, or instant messaging.

Answer to the Question # 5 (c):
Pharming redirects users to a bogus web page, even when the individual types the correct web page address into his or her browser. This is possible if pharming perpetrators gain access to the Internet address information Internet service providers (ISPs) store to speed up web browsing and the ISP companies have flawed software on their servers that allows the fraudsters to hack in and change those addresses.

Answer to the Question # 5 (d):
Packet filtering examines selected fields in the headers of data packets flowing back and forth between the trusted network and the Internet, examining individual packets in isolation. This filtering technology can miss many types of attacks.

Stateful inspection provides additional security by determining whether packets are part of an ongoing dialogue between a sender and a receiver. It sets up state tables to track information over multiple packets. Packets are accepted or rejected based on whether they are part of an approved conversation or attempting to establish a legitimate connection.

Network Address Translation (NAT) can provide another layer of protection when static packet filtering and stateful inspection are employed. NAT conceals the IP addresses of the organization's internal host computer(s) to prevent sniffer programs outside the firewall from ascertaining them and using that information to penetrate internal systems.

Application proxy filtering examines the application content of packets. A proxy server stops data packets originating outside the organization, inspects them, and passes a proxy to the other side of the firewall. If a user outside the company wants to communicate with a user inside the organization, the outside user first communicates with the proxy application, and the proxy application communicates with the firm's internal computer. Likewise, a computer user inside the organization goes through the proxy to talk with computers on the outside.

Answer to the Question # 5 (e):
Encryption of data has become an important way to protect data and other computer network resources, especially on the Internet, intranets, and extranets.

Passwords, messages, files, and other data can be transmitted in scrambled form and unscrambled by computer systems for authorized users only. Encryption involves using special mathematical algorithms, or keys, to transform digital data into a scrambled code before they are transmitted, and then to decode the data when they are received.

The most widely used encryption method uses a pair of public and private keys unique to each individual. For example, e-mail could be scrambled and encoded using a unique public key for the recipient that is known to the sender. After the e-mail is transmitted, only the recipient's secret private key could unscramble the message.

There are several competing software encryption standards, but the top two are RSA (by RSA Data Security) and PGP (which stands for "pretty good privacy"), a popular encryption program available on the Internet.

Answer to the Question # 6 (a):
Systems Thinking

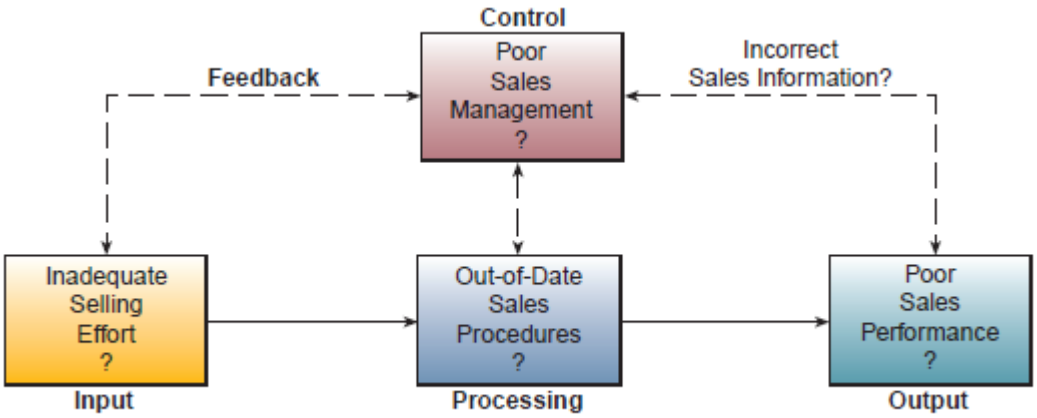
Using systems thinking to understand a problem or opportunity is one of the most important aspects of the systems approach. The essence of the discipline of systems thinking is "seeing the forest *and* the trees" in any situation by:

• Seeing *interrelationships* among *systems* rather than linear cause-and-effect chains whenever events occur.

• Seeing *processes* of change among *systems* rather than discrete "snapshots" of change, whenever changes occur. One way of practicing systems thinking is to try to find systems, subsystems, and components of systems in any situation you are studying. This is also known as using a *systems context*, or having a *systemic view* of a situation. For example, the business organization or business process in which a problem or opportunity arises could be viewed as a system of input, processing, output, feedback, and control components.

Then to understand a problem and solve it, we would determine whether these basic systems functions are being properly performed. See Figure below.

Example. The sales process of a business can be viewed as a system. We could then ask: Is poor sales performance (output) caused by inadequate selling effort (input), out-of-date sales procedures (processing), incorrect sales information (feedback), or inadequate sales management (control)? Figure illustrates this concept.



Answer to the Question # 6 (b):
Businesses increasingly accept the existence of a "shadow" IT culture, in which end users install uncontrolled rogue technology to make good the shortcomings of overstretched IT departments. Rogue IT includes users who install software or tamper with existing software or macros without the IT department's consent, according to a survey by integration specialist Blue Prism. Budget and resource constraints often lead to elements of rogue behavior, reported by 67 percent of respondents

to the survey. Twenty-four percent believed that rogue IT isn't used in their organizations, and 10 percent admitted that they didn't know.

These systems are not necessarily simple variations on the Excel spreadsheet. On the contrary, they can be very sophisticated—rivaling and even exceeding any technological solution produced by IT departments. Such systems range from consumer solutions like Google Apps to highly tailored ones. It seems that end users are increasingly aware nowadays that their IT department cannot always deliver a practical solution for their needs, which can lead to the creation of a shadow IT culture within an organization, whereby users actively install their own applications or find their own work-around solutions in order to do their day-to-day job.

This is often because IT departments have to manage business-critical projects, sometimes at the expense of helping business users with tactical change requests. Indeed, more than 52 percent reported that working on strategic projects was the main focus for their department, with 40 percent saying that delivering day-to-day business change requests was their priority. The Blue Prism survey, however, also challenges the traditional perception that IT departments frown upon rogue behavior by users. The survey concludes that many IT departments fully understand why pockets of rogue behavior exist, and it reveals that these departments were equally pragmatic when asked for the best way of dealing with it.

Answer to the Question # 6 (c):
An overview of the implementation process:

Implementation activities are needed to transform a newly developed information system into an operational system for end user.

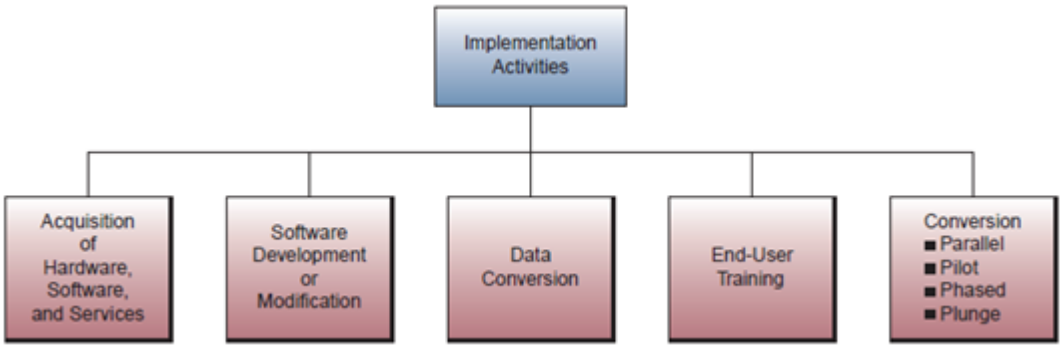


Figure above illustrates that the systems implementation stage involves hardware and software acquisition, software development, testing of programs and procedures, conversion of data resources, and a variety of conversion alternatives. It also involves the education and training of end users and specialists who will operate a new system. Implementation can be a difficult and time-consuming process; however, it is vital in ensuring the success of any newly developed system. Even a well-designed system will fail if it is not properly implemented, which is why the implementation process typically requires a project management effort on the part of IT and business unit managers. They must enforce a project plan, which includes job responsibilities, timetables for major stages of development, and financial budgets. This is necessary if a project is to be completed on time and within its established budget, while still meeting its design objectives. Figure above illustrates the activities and timetables that might be required to implement an intranet for a new employee benefits system in the human resource department of a company.

Answer to the Question # 7 (a):
The Basel Accords (Basel I, Basel II and Basel III) regulate the minimum amount of capital for financial organizations based on the level of risk they face. The Basel Committee on Banking Supervision recommends conditions and capital requirements that should be fulfilled to manage risk exposure.

These conditions will ideally result in an improvement in:
- Credit risk,
- Operational risk,
- Market risk.

Answer to the Question # 7 (b):
The following are the steps an IS auditor would perform to determine an organization's level of compliance with external requirements:
- Identify those government or other relevant external requirements dealing with:
  – Electronic data, personal data, copyrights, e-commerce, e-signatures, etc.
  – Computer system practices and controls
  – The manner in which computers, programs and data are stored
  – The organization or the activities of information technology services
  – IS audits
- Document applicable laws and regulations.
- Assess whether the management of the organization and the IT function have considered the relevant external requirements in making plans and in setting policies, standards and procedures, as well as business application features.
- Review internal IT department/function/activity documents that address adherence to laws applicable to the industry.
- Determine adherence to established procedures that address these requirements.
- Determine if there are procedures in place to ensure contracts or agreements with external IT services providers reflect any legal requirements related to responsibilities.

Answer to the Question # 7 (c):
Standards contain statements of mandatory requirements for IS audit and assurance. They inform:

- IS audit and assurance professionals of the minimum level of acceptable performance required to meet the professional responsibilities set out in the ISACA Code of Professional Ethics.
- Management and other interested parties of the profession's expectations concerning the work of practitioners.
- Holders of the Certified Information Systems Auditor (CISA) designation of their requirements. Failure to comply with these standards may result in an investigation into the CISA holder's conduct by the ISACA Board of Directors or appropriate ISACA group and, ultimately, in disciplinary action.

Answer to the Question # 7 (d):
The framework for the ISACA IS Audit and Assurance Standards provides for multiple levels of documents:

- Standards define mandatory requirements for IS audit and assurance and reporting.
- Guidelines provide guidance in applying IS Audit and Assurance Standards. The IS auditor should consider them in determining how to achieve implementation of the above standards, use professional judgment in their application and be prepared to justify any departure from the standards.
- Tools and techniques provide examples of processes an IS auditor might follow in an audit engagement. The tools and techniques documents provide information on how to meet the standards when completing IS auditing work, but do not set requirements.

Answer to the Question # 7 (e):
Forensic auditing has been defined as auditing specialized in discovering, disclosing and following up on fraud and crimes. The primary purpose of such a review is the development of evidence for review by law enforcement and judicial authorities. Forensic professionals have been called on to participate in investigations related to corporate fraud and cybercrime. In cases where computer resources may have been misused, further investigation is necessary to gather evidence for possible criminal activity that can then be reported to appropriate authorities. A computer forensic investigation includes the analysis of electronic devices such as computers, smartphones, disks, switches, routers, hubs and other electronic equipment. An IS auditor possessing the necessary skills can assist the information security manager in performing forensic investigations and conduct the audit of the systems to ensure compliance with the evidence collection procedures for forensic investigation. Electronic evidence is vulnerable to changes; therefore, it is necessary to handle electronic evidence with utmost care and controls should ensure that no manipulation can occur. Chain of custody for electronic evidence should be established to meet legal requirements.

Improperly handled computer evidence is subject to being ruled inadmissible by judicial authorities. The most important consideration for a forensic auditor is to make a bit-stream image of the target drive and examine that image without altering date stamps or other information attributable to the examined files. Further, forensic audit tools and techniques such as data mapping for security and privacy risk assessment, and the search for intellectual property for data protection, are also being used for prevention, compliance and assurance.

Answer to the Question # 7 (f):
Audit documentation should include, at a minimum, a record of the following:

- Planning and preparation of the audit scope and objectives.
- Description and/or walk-throughs on the scoped audit area.
- Audit program.
- Audit steps performed and audit evidence gathered.
- Use of services of other auditors and experts.
- Audit findings, conclusions and recommendations.
- Audit documentation relation with document identification and dates.

It is also recommended that documentation include:

- A copy of the report issued as a result of the audit work.
- Evidence of audit supervisory review.

The documentation format and media are optional, but due diligence and good practices require that work papers are dated, initialed, page-numbered, relevant, complete, clear, self-contained and properly labeled, filed and kept in custody. Work papers may be automated. IS auditors should particularly consider how to maintain integrity and protection of audit test evidence to preserve their proof value in support of audit results.